

Challenges in automation

One significant challenge with the current cloud service implementations is the reliance on a web browser for user authentication. This dependency prevents the full automation of background (daemon) processes. To create an automated environment for delegated access, developers need to reverse-engineer the WebAuthn process. This involves inspecting and analysing the requests and responses that occur in the background during WebAuthn in the browser. Let us meticulously map these requests and responses so that developers can understand how to replicate these steps programmatically.

Figure 1 is a screenshot of a completed authentication from my sample user account after finishing WebAuthn.

To trace back the steps and understand what went wrong, it's necessary to reverse-engineer the process by examining the requests and responses that occurred before the authorisation code was returned. This can be done by going to the network tab under the browser's inspect element tool, where you will find a series of recorded logs showing the sequence of network activities.

By analysing these logs, you can map out the requests and responses, identify where the process deviated from the expected flow, and correct any issues to ensure successful API access in future attempts.

WebAuthn mapping

To prepare an appropriate WebAuthn mapping, it is beneficial to start by inspecting the most recent GET/POST requests. Begin by identifying the request that contains the authorisation code. Check the header and payload of this request. In this case, the authorisation code is found in the header of a GET request to the localhost domain, which shows a 404 Not Found status code in the web browser.

Here's how one can do it.

Open network tab: In the browser, open the developer tools and navigate to the *Network* tab.

Locate the authorisation code request: Find the most recent GET request that contains the authorisation code in its header. This request will typically be directed to the localhost domain.

Inspect the request and response:

- **Header:** Look at the headers to find the authorisation code.

Status	Method	Domain	File	Initiator	Type	Transferred	Size
300	GET	logincdn.msauth.net	Converged_v22057_mG-wAdV..._sg1Xxms67SSA2.css	stylesheet	css	21.04 kB	111.52 kB
300	GET	logincdn.msauth.net	ConvergedPCanaryVStrings.en-gb_t3H8kSMIOkMV3XV7wAriAg2.js	partnerpost.srf:13 (script)	js	1.61 kB	1.69 kB
300	GET	logincdn.msauth.net	favicon.ico	FaviconLoader.sys.mui:1	image/icon	17.91 kB	17.17 kB
300	GET	logincdn.msauth.net	ConvergedPCanaryV_Core1-1m4Z3_e16FZd01ADsw2.js	partnerpost.srf:13 (script)	js	83.56 kB	287.85 kB
400	POST	login.microsoft.com	msaidpvabdate?uaid=8277f0d6cb7645bc86a4c79a605ab650&client...	ConvergedPCanaryV_C...	json	1.74 kB	444 B
200	OPTIONS	login.microsoft.com	msaidpvabdate?uaid=8277f0d6cb7645bc86a4c79a605ab650&client...	shr	plain	937 B	0 B
300	GET	logincdn.msauth.net	2_11d9e3bcdfe9ce5ce5ace2d129f1c4.svg	ConvergedPCanaryV_C...	svg	1.45 kB	1.86 kB
300	GET	logincdn.msauth.net	marching_ants_white_8257b0707cbe1d0bd2661b80068678fe.gif	ConvergedPCanaryV_C...	gif	3.41 kB	2.67 kB
300	GET	logincdn.msauth.net	marching_ants_986f40b5a9dc7d39ef8396797f61b323.gif	ConvergedPCanaryV_C...	gif	4.36 kB	3.62 kB
300	GET	logincdn.msauth.net	microsoft_logo_564db913a7fa0ca42727161cd031bef.svg	ConvergedPCanaryV_C...	svg	2.21 kB	3.65 kB
300	GET	logincdn.msauth.net	oneDx_f2e0f4a029670f1...	ConvergedPCanaryV_C...	js	61.84 kB	190.15 kB
300	GET	logincdn.msauth.net	microsoft_logo_564db913a7fa0ca42727161cd031bef.svg	img	svg	cached	65.66 kB
300	GET	logincdn.msauth.net	2_11d9e3bcdfe9ce5ce5ace2d129f1c4.svg	img	svg	cached	74.40 kB
300	GET	logincdn.msauth.net	marching_ants_white_8257b0707cbe1d0bd2661b80068678fe.gif	img	img	cached	3.97 kB
300	GET	logincdn.msauth.net	marching_ants_986f40b5a9dc7d39ef8396797f61b323.gif	img	gif	cached	3.97 kB
300	POST	login.live.com	post.srf?client_id=51483342-085c-4d06-bf88-d50c7252078&uaid=82...	document	html	9.20 kB	12.18 kB
204	POST	browser.events.data...	/OneCollector/1.0/?cors=true&content-type=application/x-json-stre...	oneDx_f2e0f4a029670f1...	plain	3.46 kB	0 B
300	GET	logincdn.msauth.net	kmsi_en-gb_kmuZgc4zi_BGWoHfHfQ8A2.js	script	js	163.15 kB	624.92 kB
300	GET	logincdn.msauth.net	onedx-analytics-cs_178286d237b77729f1c3_en-gb.js	kmu_en-gb_kmuZgc4zi...	js	33.82 kB	90.70 kB
300	GET	logincdn.msauth.net	microsoft_logo_ee5cd9fb6248c938fd0.svg	kmu_en-gb_kmuZgc4zi...	svg	2.22 kB	3.65 kB
300	POST	login.live.com	GetExperimentAssignments.srf	kmsi_en-gb_kmuZgc4zi...	json	592 B	64 B
300	GET	logincdn.msauth.net	2_bc3d32a69695f78c19d.svg	img	svg	1.45 kB	1.86 kB
300	GET	logincdn.msauth.net	favicon.ico	FaviconLoader.sys.mui:1	image/icon	cached	17.17 kB
304	POST	browser.events.data...	/OneCollector/1.0/?cors=true&content-type=application/x-json-stre...	onedx-analytics-cs_178...	plain	8.06 kB	0 B
300	POST	login.live.com	post.srf?client_id=51483342-085c-4d06-bf88-d50c7252078&uaid=82...	document	html	9.42 kB	1.25 kB
300	GET	login.live.com	favicon.ico	FaviconLoader.sys.mui:1	image/icon	MS_BINDING_ABORTED	
302	POST	login.microsoftonline...	oauth2msa	Post.srf:1 (document)	html	11.22 kB	6.33 kB
404	GET	localhost	/myapp/?code=0.AQ3A0BzDhDusRstLVGdgCM-b31v2HVSXg5BnKR...	document	html	6.50 kB	6.33 kB
404	GET	localhost	favicon.ico	FaviconLoader.sys.mui:1	html	5.02 kB	4.84 kB

Figure 2: OAuth2msa response header